nimiq-primitives: Out-of-bounds panic in KeyNibbles::Add from oversized child suffix in a deserialized proof

Report Type: Weekly · Generated: July 16, 2026 21:12 UTC · Coverage: Jul 16 - Jul 16, 2026

1 Total Advisories	0 Critical	0 High	0 Medium
LOW Severity	3.7 CVSS / Risk Score	TLP:CLEAR TLP Classification	PRO Customer Tier

Executive Summary

Impact A malicious peer acting as a state-sync source can crash a syncing node with a crafted `TrieChunk` whose proof contains a `TrieNodeChild` whose `suffix`, when concatenated with the parent key via `KeyNibbles::Add`, exceeds the fixed 63-byte backing array. `Add` (`primitives/src/key_nibbles.rs:332` / `:341`) indexes `bytes[self.bytes_len()..self.bytes_len() + other.bytes_len()]` with no combined-length check, causing an out-of-bounds slice panic (both the even- and odd-length branches). `KeyNibbles` deserialization validates only the individual `length <= 126`, not the combined parent + suffix length. The panic occurs at `put_chunk` → `child.key()` → `is_stump()` → `+`, i.e. **before** `proof.verify()`, so no valid proof is required. As with the related `child_index` issue, exploitation requires being the victim's sync peer during state sync, and the resulting crash is transient (the node restarts and re-syncs). Affected: core-rs-albatross <= 1.5.1 (`nimiq-primitives`).

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
nimiq-primitives: Out-of-bounds panic in KeyNibbles::Add from oversize	LOW	3.7	-	### Impact A malicious peer acting as a state-sync source can crash a syncin

MITRE ATT&CK® v15 Mapping

Technique density score: **0.0** · Techniques observed: **0** · Tactics covered: **0**

MITRE ATT&CK techniques pending analyst enrichment. Deploy detection rules from Section 6 to identify related activity.

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	-

Indicators of Compromise (IOCs)

IOC extraction for this advisory is pending enrichment pipeline completion. PRO subscribers receive real-time IOC push to SIEM/SOAR via the SENTINEL APEX webhook at: **GET /api/v1/intel/iocs?advisory={id}**. Full IOC packages include IPv4, domain, SHA256, and URL indicators with confidence scores, first-seen timestamps, and STIX 2.1 formatted bundles.

Detection Engineering

Deploy these production-ready detection rules into your SIEM platform to identify exploitation attempts in real time. Compatible with Microsoft Sentinel, Splunk ES, and any Sigma-compatible platform.

Sigma Rule - Webserver / Process Monitoring

```
title: SENTINEL APEX - Heap Overflow Exploitation Attempt
id: cdb-cdb-advisory-det
status: experimental
description: |
Detects exploitation attempts targeting CDB-ADVISORY (heap-based overflow).
Monitors for anomalous process crashes and memory allocation failures.
references:
- https://intel.cyberdudebivash.com
author: CyberDudeBivash SENTINEL APEX
date: 2026/07/16
tags:
- attack.initial_access
- attack.t1190
- attack.execution
- attack.t1203
logsource:
category: process_creation
product: windows
detection:
selection_crash:
EventID: 1000
ApplicationName|contains|any:
- 'nimiq-primitives:'
selection_wer:
EventID: 1001
AppPath|contains|any:
- 'nimiq-primitives:'
condition: selection_crash OR selection_wer
falsepositives:
- Legitimate software bugs / crash reporting
level: medium
```

Microsoft Sentinel - KQL Query

```
// SENTINEL APEX - nimiq-primitives: Out-of-bounds panic in KeyNibbles::Add from oversized child suffix in a deserialized proof
// Advisory | Microsoft Sentinel KQL
let time_window = ago(24h);
SecurityAlert
| where TimeGenerated > time_window
| where Description has "nimiq-primitives: Out-of-bounds panic in"
or AlertName has "nimiq-primitives: Out-of-bounds panic in"
or ExtendedProperties has "nimiq-primitives: Out-of-bounds panic in"
| extend Rule = "APEX-ADVISORY", Severity = "LOW"
| project TimeGenerated, AlertName, AlertSeverity, Entities, Description, Rule, Severity
| order by TimeGenerated desc
```

Incident Response Playbook

Phase 1 - 0-24 Hours (Containment)

1. Activate IR team; assign lead analyst and executive sponsor.
2. Isolate or WAF-shield nimiq instances exposed to the internet.
3. Enable verbose access logging on all nimiq endpoints immediately.
4. Pull last 72h of web server and application logs for forensic baselining.
5. Check SENTINEL APEX IOC feeds and SIEM alerts for exploitation hits in your environment.
6. Notify relevant internal stakeholders and legal / compliance team.

Phase 2 - 24-72 Hours (Eradication)

1. Apply vendor patch for nimiq or implement recommended mitigation.
2. Deploy Sigma and KQL detection rules from Section 6 across all SIEM platforms.
3. Rotate all API keys, service account credentials, and session tokens.
4. Conduct forensic timeline reconstruction for potential compromise window.
5. Validate patch deployment across 100% of affected instances via asset inventory.

Phase 3 - 7 Days (Recovery & Hardening)

1. Conduct post-incident review and update incident response runbooks.
2. Threat hunt for lateral movement or persistence artifacts using MITRE ATT&CK mapping.
3. Update asset inventory with patched version information and closure evidence.
4. Submit findings to internal risk register and CISO dashboard.
5. Schedule follow-up vulnerability scan to confirm remediation completeness.

Financial Impact Analysis (FAIR Model)

$20K - $180K	**$60K**	**$25K/day**	**N/A**
Breach Cost Range (FAIR)	IBM Cost of Breach 2025 Median	Business Interruption Cost	Regulatory Fine Exposure

Low severity findings require targeted patches. Aggregated low-severity debt compounds to medium breach probability within 12 months.

Remediation Cost Estimate: $15K · Includes engineering time, IR retainer activation, forensic investigation, and customer notification costs.

Regulatory & Compliance Implications

Organizations processing this advisory must evaluate obligations under applicable regulatory frameworks. The table below maps this threat to relevant compliance requirements.

Framework	Reference	Obligation
ISO 27001:2022	A.8.8	Track and remediate within standard 90-day patch cycle
NIST CSF 2.0	ID.RA	Include in regular vulnerability risk assessment

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Monitor nimiq-primitives: Out-of-bounds panic in KeyNibbles::Add from oversized child suffix in a deserialized proof for escalation.
2. Apply patches in next maintenance window.
3. Apply vendor patch for nimiq-primitives: Out-of-bounds panic in KeyNibbles::Add from oversized child suffix in a deserialized proof immediately - check NVD for official fix guidance.
4. Enable enhanced logging and alerting on all systems running affected software versions.
5. Deploy the Sigma detection rule from this report into your SIEM platform (Sentinel / Splunk / Elastic).
6. Audit all internet-facing instances of affected products and confirm patch deployment.
7. Conduct a threat hunt using MITRE ATT&CK techniques mapped in this advisory.

Appendix - Report Metadata & Legal

Field	Value
Report ID	intel--fa15eaa8e99b0506faed6922
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v166.0 GOD-MODE
Generated At	2026-07-16T21:12:59.93846
Customer Tier	PRO
Customer Email	-
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice